

Analisis Kepatuhan Keamanan Informasi Berdasarkan Standar ISO/IEC 27001:2013 Menggunakan Automated Vulnerability Scanner

Rohmani Firdaus

2402072

Abstrak Keamanan informasi pada institusi pendidikan tinggi menjadi aspek krusial seiring meningkatnya ketergantungan pada sistem berbasis web untuk pelayanan akademis. Penelitian ini bertujuan untuk menganalisis tingkat kepatuhan dan keamanan situs web akademik <https://purbaya.ac.id> terhadap standar internasional ISO/IEC 27001:2013. Metodologi yang digunakan adalah pemindaian kerentanan otomatis (*automated vulnerability scanning*) menggunakan *tool* Acunetix dengan profil *Full Scan*. Hasil pemindaian menunjukkan adanya dua celah keamanan utama yang teridentifikasi dalam 6 *alerts*, yaitu ketiadaan proteksi *Cross-Site Request Forgery* (CSRF) yang berdampak pada kontrol akses istimewa (Klausul 9.2.3), serta hilangnya deklarasi header *Content-Type* pada 5 elemen web yang berdampak pada prosedur instalasi perangkat lunak operasional (Klausul 12.5.1). Artikel ini membahas dampak teknis dari celah tersebut serta memberikan rekomendasi remediasi konkret untuk meningkatkan postur keamanan sistem.

Kata Kunci: ISO/IEC 27001:2013, Kepatuhan Keamanan, Acunetix, CSRF, *Content-Type*, Keamanan Web.

1. Pendahuluan

Sistem informasi universitas atau politeknik mengelola volume data sensitif yang besar, mulai dari data pribadi mahasiswa hingga dokumentasi internal institusi. Kegagalan dalam mengamankan infrastruktur digital ini dapat memicu insiden kebocoran data dan penurunan reputasi organisasi.

Standardisasi manajemen keamanan informasi yang diakui secara global adalah ISO/IEC 27001:2013, yang menyediakan model terstruktur untuk menetapkan, menerapkan, mengoperasikan, memantau, dan meningkatkan Sistem Manajemen Keamanan Informasi (SMKI). Untuk mengevaluasi efektivitas kontrol tersebut secara berkala, audit teknis berupa *vulnerability assessment* perlu dilakukan guna mendeteksi celah keamanan sebelum dieksploitasi oleh pihak tidak bertanggung jawab. Penelitian ini melakukan audit kepatuhan

berbasis parameter ISO 27001:2013 pada domain institusi pendidikan tinggi guna memetakan risiko teknis yang ada.

2. Metodologi Penelitian

Penelitian ini menerapkan metode pengujian penetrasi pasif-ke-aktif yang terotomatisasi. Objek penelitian adalah portal web utama <https://purbaya.ac.id>. Pemindaian dilakukan pada tanggal 14 April 2026 dengan durasi pemindaian selama 7 menit 43 detik menggunakan metode *Full Scan* menyeluruh.

Instrumen audit yang digunakan adalah Acunetix Compliance Scanner yang dikonfigurasi khusus untuk memetakan setiap temuan teknis (*vulnerability*) langsung ke klausul kontrol keamanan ISO/IEC 27001:2013. Evaluasi risiko teknis diukur menggunakan visualisasi skor *Common Vulnerability Scoring System* (CVSS) versi 2 dan versi 3.

3. Hasil dan Pembahasan

Berdasarkan hasil audit kepatuhan, mayoritas kontrol keamanan yang dipindai berada pada status *clean* atau bebas dari ancaman aktif. Namun, pemindai mendeteksi total 6 *alerts* yang terkonsentrasi pada dua klausul kontrol ISO 27001:2013.

3.1. Analisis Klausul 9.2.3: Management of Privileged Access Rights

Pada kategori kontrol manajemen hak akses istimewa, ditemukan 1 *alert* kritis berupa **HTML Form Without CSRF Protection** dengan identifikasi kelemahan **CWE-352**.

- **Analisis Risiko:** Berdasarkan metrik CVSSv3, celah ini memiliki *Base Score* **4.3 (Medium)**. *Cross-Site Request Forgery* (CSRF) terjadi ketika penyerang mengeksploitasi mekanisme kepercayaan peramban terhadap sesi autentikasi pengguna. Melalui manipulasi form HTML tanpa token proteksi ini, penyerang dapat menjebak pengguna—termasuk administrator sistem—untuk mengeksekusi instruksi ilegal (seperti perubahan password atau transfer data) tanpa disadari.

3.2. Analisis Klausul 12.5.1: Installation of Software on Operational Systems

Pada kategori kontrol instalasi perangkat lunak di sistem operasional, terdeteksi 5 *alerts* dengan tipe kerentanan **Content Type is Not Specified** dengan identifikasi **CWE-16** (Configuration Error).

- **Analisis Risiko:** Temuan ini diklasifikasikan sebagai low/informational dengan *Base Score* **0.0** pada skala CVSSv2. Kerentanan ini muncul karena server web tidak mengirimkan header parameter Content-Type dalam respon HTTP-nya. Kondisi hilangnya header memaksa peramban melakukan *MIME-sniffing* untuk menebak format file. Ketidakpastian penanganan data ini secara teoretis dapat dieksploitasi untuk

menyisipkan skrip berbahaya (seperti *Cross-Site Scripting* lewat file teks) yang dapat mengelabui proteksi keamanan peramban klien.

4. Kesimpulan dan Rekomendasi Remediasi

Sistem informasi <https://purbaya.ac.id> memiliki fondasi keamanan yang cukup baik karena sebagian besar perimeter kontrol ISO 27001:2013 tidak memicu *security alert*. Kendati demikian, guna mencapai kepatuhan penuh (*full compliance*), langkah-langkah remediasi berikut wajib diimplementasikan segera:

1. **Remediasi Klausul 9.2.3 (CWE-352):** Pengembang aplikasi harus mengintegrasikan mekanisme token anti-CSRF yang bersifat dinamis, unik, dan berbasis sesi (*session-bound*) pada setiap form penyerahan data berbasis metode POST/PUT/DELETE di dalam arsitektur web aplikasi.
2. **Remediasi Klausul 12.5.1 (CWE-16):** Melakukan penguatan konfigurasi (*hardening*) pada sisi web server (seperti Apache atau Nginx) serta skrip aplikasi backend untuk memastikan header Content-Type dideklarasikan secara eksplisit (misalnya: Content-Type: text/html; charset=utf-8) pada setiap berkas dan halaman yang ditransmisikan ke peramban.

Daftar Pustaka

- [1] Acunetix. (2026). *Compliance Report: ISO 27001:2013 Vulnerability Assessment Report for purbaya.ac.id*. Generated on 14 April 2026.
- [2] International Organization for Standardization. (2013). *ISO/IEC 27001:2013 - Information technology — Security techniques — Information security management systems — Requirements*. Geneva: ISO/IEC.
- [3] MITRE. (2026). *CWE-352: Cross-Site Request Forgery (CSRF)*. Common Weakness Enumeration.
- [4] MITRE. (2026). *CWE-16: Configuration*. Common Weakness Enumeration.